



WebApp Test

Report generated by Tenable Nessus™

Sat, 02 Aug 2025 09:17:09 IST

TABLE OF CONTENTS

Vulnerabilities by Plugin

• 125855 (1) - phpMyAdmin prior to 4.8.6 SQLi vulnerability (PMASA-2019-3).....	5
• 171340 (1) - Apache Tomcat SEoL (<= 5.5.x).....	7
• 36171 (1) - phpMyAdmin Setup Script Configuration Parameters Arbitrary PHP Code Injection (PMASA-200.....	8
• 85582 (2) - Web Application Potentially Vulnerable to Clickjacking.....	10
• 11213 (1) - HTTP TRACE / TRACK Methods Allowed.....	12
• 11229 (1) - Web Server info.php / phpinfo.php Detection.....	15
• 11411 (1) - Backup Files Disclosure.....	17
• 12085 (1) - Apache Tomcat Default Files.....	18
• 36083 (1) - phpMyAdmin file_path Parameter Vulnerabilities (PMASA-2009-1).....	20
• 40984 (1) - Browsable Web Directories.....	22
• 46803 (1) - PHP expose_php Information Disclosure.....	24
• 49142 (1) - phpMyAdmin setup.php Verbose Server Name XSS (PMASA-2010-7).....	25
• 51425 (1) - phpMyAdmin error.php BBcode Tag XSS (PMASA-2010-9).....	27
• 26194 (2) - Web Server Transmits Cleartext Credentials.....	29
• 42057 (2) - Web Server Allows Password Auto-Completion.....	31
• 34850 (1) - Web Server Uses Basic Authentication Without HTTPS.....	32
• 11219 (25) - Nessus SYN scanner.....	33
• 10107 (2) - HTTP Server Type and Version.....	36
• 10662 (2) - Web mirroring.....	37
• 11032 (2) - Web Server Directory Enumeration.....	41
• 11419 (2) - Web Server Office File Inventory.....	43
• 24260 (2) - HyperText Transfer Protocol (HTTP) Information.....	44
• 43111 (2) - HTTP Methods Allowed (per directory).....	47
• 49704 (2) - External URLs.....	50
• 49705 (2) - Web Server Harvested Email Addresses.....	52
• 50344 (2) - Missing or Permissive Content-Security-Policy frame-ancestors HTTP Response Header.....	54

• 50345 (2) - Missing or Permissive X-Frame-Options HTTP Response Header.....	57
• 85601 (2) - Web Application Cookies Not Marked HttpOnly.....	59
• 85602 (2) - Web Application Cookies Not Marked Secure.....	63
• 91815 (2) - Web Application Sitemap.....	68
• 100669 (2) - Web Application Cookies Are Expired.....	70
• 11422 (1) - Web Server Unconfigured - Default Install Page Present.....	72
• 11424 (1) - WebDAV Detection.....	73
• 17219 (1) - phpMyAdmin Detection.....	74
• 18261 (1) - Apache Banner Linux Distribution Disclosure.....	75
• 19941 (1) - TWiki Detection.....	76
• 20108 (1) - Web Server / Application favicon.ico Vendor Fingerprinting.....	77
• 24004 (1) - WebDAV Directory Enumeration.....	78
• 39446 (1) - Apache Tomcat Detection.....	79
• 40665 (1) - Protected Web Page Detection.....	80
• 40773 (1) - Web Application Potentially Sensitive CGI Parameter Detection.....	81
• 48204 (1) - Apache HTTP Server Version.....	82
• 48243 (1) - PHP Version Detection.....	83
• 72771 (1) - Web Accessible Backups.....	84
• 84574 (1) - Backported Security Patch Detection (PHP).....	85

Vulnerabilities by Plugin

125855 (1) - phpMyAdmin prior to 4.8.6 SQLi vulnerability (PMASA-2019-3)

Synopsis

The remote web server hosts a PHP application that is affected by SQLi vulnerability.

Description

According to its self-reported version number, the phpMyAdmin application hosted on the remote web server is prior to 4.8.6. It is, therefore, affected by a SQL injection (SQLi) vulnerability that exists in designer feature of phpMyAdmin. An unauthenticated, remote attacker can exploit this to inject or manipulate SQL queries in the back-end database, resulting in the disclosure or manipulation of arbitrary data.

Note that Nessus has not attempted to exploit these issues but has instead relied only on the application's self-reported version number.

See Also

<http://www.nessus.org/u?c9d7fc8c>

Solution

Upgrade to phpMyAdmin version 4.8.6 or later.

Alternatively, apply the patches referenced in the vendor advisories.

Risk Factor

High

CVSS v3.0 Base Score

9.8 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

CVSS v3.0 Temporal Score

8.5 (CVSS:3.0/E:U/RL:O/RC:C)

VPR Score

5.9

EPSS Score

0.0172

CVSS v2.0 Base Score

7.5 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P)

CVSS v2.0 Temporal Score

5.5 (CVSS2#E:U/RL:OF/RC:C)

References

BID	108617
CVE	CVE-2019-11768

Plugin Information

Published: 2019/06/13, Modified: 2024/11/22

Plugin Output

192.168.1.4 (tcp/80/www)

```
URL           : http://192.168.1.4/phpMyAdmin
Installed version : 3.1.1
Fixed version  : 4.8.6
```

171340 (1) - Apache Tomcat SEoL (<= 5.5.x)

Synopsis

An unsupported version of Apache Tomcat is installed on the remote host.

Description

According to its version, Apache Tomcat is less than or equal to 5.5.x. It is, therefore, no longer maintained by its vendor or provider.

Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

See Also

<https://tomcat.apache.org/tomcat-55-eol.html>

Solution

Upgrade to a version of Apache Tomcat that is currently supported.

Risk Factor

Critical

CVSS v3.0 Base Score

10.0 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)

CVSS v2.0 Base Score

10.0 (CVSS2#AV:N/AC:L/Au:N/C/I:C/A:C)

Plugin Information

Published: 2023/02/10, Modified: 2024/05/06

Plugin Output

192.168.1.4 (tcp/8180/www)

```
URL : http://192.168.1.4:8180/
Installed version : 5.5
Security End of Life : September 30, 2012
Time since Security End of Life (Est.) : >= 12 years
```

36171 (1) - phpMyAdmin Setup Script Configuration Parameters Arbitrary PHP Code Injection (PMASA-2009-4)

Synopsis

The remote web server contains a PHP application that is affected by a code execution vulnerability.

Description

The setup script included with the version of phpMyAdmin installed on the remote host does not properly sanitize user-supplied input before using it to generate a config file for the application. This version is affected by the following vulnerabilities :

- The setup script inserts the unsanitized verbose server name into a C-style comment during config file generation.
- An attacker can save arbitrary data to the generated config file by altering the value of the 'textconfig' parameter during a POST request to config.php.

An unauthenticated, remote attacker can exploit these issues to execute arbitrary PHP code.

See Also

<https://www.tenable.com/security/research/tra-2009-02>

http://www.phpmyadmin.net/home_page/security/PMASA-2009-4.php

Solution

Upgrade to phpMyAdmin 3.1.3.2. Alternatively, apply the patches referenced in the project's advisory.

Risk Factor

High

VPR Score

6.7

EPSS Score

0.0116

CVSS v2.0 Base Score

7.5 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P)

CVSS v2.0 Temporal Score

5.5 (CVSS2#E:U/RL:OF/RC:C)

References

BID	34526
CVE	CVE-2009-1285
XREF	TRA:TRA-2009-02
XREF	SECUNIA:34727
XREF	CWE:94

Plugin Information

Published: 2009/04/16, Modified: 2022/04/11

Plugin Output

192.168.1.4 (tcp/80/www)

85582 (2) - Web Application Potentially Vulnerable to Clickjacking

Synopsis

The remote web server may fail to mitigate a class of web application vulnerabilities.

Description

The remote web server does not set an X-Frame-Options response header or a Content-Security-Policy 'frame-ancestors' response header in all content responses. This could potentially expose the site to a clickjacking or UI redress attack, in which an attacker can trick a user into clicking an area of the vulnerable page that is different than what the user perceives the page to be. This can result in a user performing fraudulent or malicious transactions.

X-Frame-Options has been proposed by Microsoft as a way to mitigate clickjacking attacks and is currently supported by all major browser vendors.

Content-Security-Policy (CSP) has been proposed by the W3C Web Application Security Working Group, with increasing support among all major browser vendors, as a way to mitigate clickjacking and other attacks. The 'frame-ancestors' policy directive restricts which sources can embed the protected resource.

Note that while the X-Frame-Options and Content-Security-Policy response headers are not the only mitigations for clickjacking, they are currently the most reliable methods that can be detected through automation. Therefore, this plugin may produce false positives if other mitigation strategies (e.g., frame-busting JavaScript) are deployed or if the page does not perform any security-sensitive transactions.

See Also

<http://www.nessus.org/u?399b1f56>

https://www.owasp.org/index.php/Clickjacking_Defense_Cheat_Sheet

<https://en.wikipedia.org/wiki/Clickjacking>

Solution

Return the X-Frame-Options or Content-Security-Policy (with the 'frame-ancestors' directive) HTTP header with the page's response.

This prevents the page's content from being rendered by another site when using the frame or iframe HTML tags.

Risk Factor

Medium

CVSS v2.0 Base Score

4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N)

References

Plugin Information

Published: 2015/08/22, Modified: 2017/05/16

Plugin Output

192.168.1.4 (tcp/80/www)

The following pages do not use a clickjacking mitigation response header and contain a clickable event :

- <http://192.168.1.4/dvwa/login.php>
- <http://192.168.1.4/mutillidae/>
- <http://192.168.1.4/mutillidae/index.php>
- <http://192.168.1.4/phpMyAdmin/>
- <http://192.168.1.4/phpMyAdmin/index.php>
- <http://192.168.1.4/twiki/bin/search>
- <http://192.168.1.4/twiki/bin/search/Main>
- <http://192.168.1.4/twiki/bin/search/Main/SearchResult>
- <http://192.168.1.4/twiki/bin/view>
- <http://192.168.1.4/twiki/bin/view/Main>
- <http://192.168.1.4/twiki/bin/view/Main/WebHome>

192.168.1.4 (tcp/8180/www)

The following pages do not use a clickjacking mitigation response header and contain a clickable event :

- <http://192.168.1.4:8180/admin/>
- <http://192.168.1.4:8180/admin/error.jsp>
- <http://192.168.1.4:8180/jsp-examples/cal/login.html>
- <http://192.168.1.4:8180/jsp-examples/checkbox/check.html>
- <http://192.168.1.4:8180/jsp-examples/colors/colors.html>
- <http://192.168.1.4:8180/jsp-examples/colors/colrs.jsp>
- <http://192.168.1.4:8180/jsp-examples/error/err.jsp>
- <http://192.168.1.4:8180/jsp-examples/error/error.html>
- <http://192.168.1.4:8180/jsp-examples/jsp2/el/functions.jsp>
- <http://192.168.1.4:8180/jsp-examples/jsp2/el/implicit-objects.jsp>
- <http://192.168.1.4:8180/jsp-examples/num/numguess.jsp>
- <http://192.168.1.4:8180/jsp-examples/plugin/plugin.jsp>
- <http://192.168.1.4:8180/jsp-examples/sessions/carts.html>
- <http://192.168.1.4:8180/jsp-examples/sessions/carts.jsp>
- <http://192.168.1.4:8180/servlets-examples/servlet/CookieExample>
- <http://192.168.1.4:8180/servlets-examples/servlet/RequestParamExample>
- <http://192.168.1.4:8180/servlets-examples/servlet/SessionExample>

11213 (1) - HTTP TRACE / TRACK Methods Allowed

Synopsis

Debugging functions are enabled on the remote web server.

Description

The remote web server supports the TRACE and/or TRACK methods. TRACE and TRACK are HTTP methods that are used to debug web server connections.

See Also

<http://www.nessus.org/u?e979b5cb>

<http://www.apacheweek.com/issues/03-01-24>

<https://download.oracle.com/sunalerts/1000718.1.html>

Solution

Disable these HTTP methods. Refer to the plugin output for more information.

Risk Factor

Medium

CVSS v3.0 Base Score

5.3 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

CVSS v3.0 Temporal Score

4.6 (CVSS:3.0/E:U/RL:O/RC:C)

VPR Score

4.0

EPSS Score

0.5589

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

CVSS v2.0 Temporal Score

3.7 (CVSS2#E:U/RL:OF/RC:C)

References

BID	9506
BID	9561
BID	11604
BID	33374
BID	37995
CVE	CVE-2003-1567
CVE	CVE-2004-2320
CVE	CVE-2010-0386
XREF	CERT:288308
XREF	CERT:867593
XREF	CWE:16
XREF	CWE:200

Plugin Information

Published: 2003/01/23, Modified: 2024/04/09

Plugin Output

192.168.1.4 (tcp/80/www)

```
To disable these methods, add the following lines for each virtual
host in your configuration file :

    RewriteEngine on
    RewriteCond %{REQUEST_METHOD} ^(TRACE|TRACK)
    RewriteRule .* - [F]

Alternatively, note that Apache versions 1.3.34, 2.0.55, and 2.2
support disabling the TRACE method natively via the 'TraceEnable'
directive.

Nessus sent the following TRACE request : \n\n----- snip
-----\nTRACE /Nessus1343987972.html HTTP/1.1
Connection: Close
Host: 192.168.1.4
Pragma: no-cache
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
Accept-Language: en
Accept-Charset: iso-8859-1,*,utf-8

----- snip ----- \n\nand received the
following response from the remote server : \n\n----- snip
-----\nHTTP/1.1 200 OK
Date: Fri, 01 Aug 2025 19:16:31 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
Keep-Alive: timeout=15, max=100
Connection: Keep-Alive
Transfer-Encoding: chunked
Content-Type: message/http
```

```
TRACE /Nessus1343987972.html HTTP/1.1
Connection: Keep-Alive
Host: 192.168.1.4
Pragma: no-cache
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
Accept-Language: en
Accept-Charset: iso-8859-1,*,utf-8

----- snip -----\n
```

11229 (1) - Web Server info.php / phpinfo.php Detection

Synopsis

The remote web server contains a PHP script that is prone to an information disclosure attack.

Description

Many PHP installation tutorials instruct the user to create a PHP file that calls the PHP function 'phpinfo()' for debugging purposes. Various PHP applications may also include such a file. By accessing such a file, a remote attacker can discover a large amount of information about the remote web server, including :

- The username of the user who installed PHP and if they are a SUDO user.
- The IP address of the host.
- The version of the operating system.
- The web server version.
- The root directory of the web server.
- Configuration information about the remote PHP installation.

Solution

Remove the affected file(s).

Risk Factor

Medium

CVSS v3.0 Base Score

5.3 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

Plugin Information

Published: 2003/02/12, Modified: 2024/11/22

Plugin Output

192.168.1.4 (tcp/80/www)

Nessus discovered the following URLs that call phpinfo() :

- <http://192.168.1.4/phpinfo.php>
- <http://192.168.1.4/mutillidae/phpinfo.php>

11411 (1) - Backup Files Disclosure

Synopsis

It is possible to retrieve file backups from the remote web server.

Description

By appending various suffixes (ie: .old, .bak, ~, etc...) to the names of various files on the remote host, it seems possible to retrieve their contents, which may result in disclosure of sensitive information.

See Also

<http://www.nessus.org/u?8f3302c6>

Solution

Ensure the files do not contain any sensitive information, such as credentials to connect to a database, and delete or protect those files that should not be accessible.

Risk Factor

Medium

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

Plugin Information

Published: 2003/03/17, Modified: 2023/07/10

Plugin Output

192.168.1.4 (tcp/80/www)

It is possible to read the following backup files :

- File : /twiki/bin/view/Main/WebHome~
URL : http://192.168.1.4/twiki/bin/view/Main/WebHome~
- File : /twiki/bin/search/Main/SearchResult~
URL : http://192.168.1.4/twiki/bin/search/Main/SearchResult~

12085 (1) - Apache Tomcat Default Files

Synopsis

The remote web server contains default files.

Description

The default error page, default index page, example JSPs and/or example servlets are installed on the remote Apache Tomcat server. These files should be removed as they may help an attacker uncover information about the remote Tomcat install or host itself.

See Also

<http://www.nessus.org/u?4cb3b4dd>

https://www.owasp.org/index.php/Securing_tomcat

Solution

Delete the default index page and remove the example JSP and servlets. Follow the Tomcat or OWASP instructions to replace or modify the default error page.

Risk Factor

Medium

CVSS v3.0 Base Score

5.3 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

Plugin Information

Published: 2004/03/02, Modified: 2024/09/03

Plugin Output

192.168.1.4 (tcp/8180/www)

The following default files were found :

<http://192.168.1.4:8180/tomcat-docs/index.html>

The server is not configured to return a custom page in the event of a client requesting a non-existent resource.

This may result in a potential disclosure of sensitive information about the server to attackers.

36083 (1) - phpMyAdmin file_path Parameter Vulnerabilities (PMASA-2009-1)

Synopsis

The remote web server contains a PHP script that is affected by multiple issues.

Description

The version of phpMyAdmin installed on the remote host fails to sanitize user-supplied input to the 'file_path' parameter of the 'bs_disp_as_mime_type.php' script before using it to read a file and reporting it in dynamically-generated HTML. An unauthenticated, remote attacker may be able to leverage this issue to read arbitrary files, possibly from third-party hosts, or to inject arbitrary HTTP headers in responses sent to third-party users.

Note that the application is also reportedly affected by several other issues, although Nessus has not actually checked for them.

See Also

<https://www.phpmyadmin.net/security/PMASA-2009-1/>

Solution

Upgrade to phpMyAdmin 3.1.3.1 or apply the patch referenced in the project's advisory.

Risk Factor

Medium

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

CVSS v2.0 Temporal Score

3.7 (CVSS2#E:U/RL:OF/RC:C)

References

BID	34253
XREF	SECUNIA:34468

Plugin Information

Published: 2009/04/03, Modified: 2022/04/11

Plugin Output

192.168.1.4 (tcp/80/www)

40984 (1) - Browsable Web Directories

Synopsis

Some directories on the remote web server are browsable.

Description

Multiple Nessus plugins identified directories on the web server that are browsable.

See Also

<http://www.nessus.org/u?0a35179e>

Solution

Make sure that browsable directories do not leak confidential information or give access to sensitive resources. Additionally, use access restrictions or disable directory indexing for any that do.

Risk Factor

Medium

CVSS v3.0 Base Score

5.3 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

Plugin Information

Published: 2009/09/15, Modified: 2021/01/19

Plugin Output

192.168.1.4 (tcp/80/www)

The following directories are browsable :

```
http://192.168.1.4/dav/
http://192.168.1.4/dvwa/dvwa/
http://192.168.1.4/dvwa/dvwa/css/
http://192.168.1.4/dvwa/dvwa/images/
http://192.168.1.4/dvwa/dvwa/includes/
http://192.168.1.4/dvwa/dvwa/includes/DBMS/
http://192.168.1.4/dvwa/dvwa/js/
http://192.168.1.4/mutillidae/documentation/
http://192.168.1.4/mutillidae/styles/
```

```
http://192.168.1.4/mutillidae/styles/ddsmoothmenu/  
http://192.168.1.4/test/  
http://192.168.1.4/test/testoutput/
```

46803 (1) - PHP expose_php Information Disclosure

Synopsis

The configuration of PHP on the remote host allows disclosure of sensitive information.

Description

The PHP install on the remote server is configured in a way that allows disclosure of potentially sensitive information to an attacker through a special URL. Such a URL triggers an Easter egg built into PHP itself.

Other such Easter eggs likely exist, but Nessus has not checked for them.

See Also

https://www.0php.com/php_easter_egg.php

<https://seclists.org/webappsec/2004/q4/324>

Solution

In the PHP configuration file, php.ini, set the value for 'expose_php' to 'Off' to disable this behavior. Restart the web server daemon to put this change into effect.

Risk Factor

Medium

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

Plugin Information

Published: 2010/06/03, Modified: 2022/04/11

Plugin Output

192.168.1.4 (tcp/80/www)

Nessus was able to verify the issue using the following URL :

<http://192.168.1.4/dvwa/dvwa/includes/DBMS/DBMS.php/?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000>

49142 (1) - phpMyAdmin setup.php Verbose Server Name XSS (PMASA-2010-7)

Synopsis

The remote web server contains a PHP application that has a cross- site scripting vulnerability.

Description

The setup script included with the version of phpMyAdmin installed on the remote host does not properly sanitize user-supplied input to the 'verbose server name' field.

A remote attacker could exploit this by tricking a user into executing arbitrary script code.

See Also

<https://www.tenable.com/security/research/tra-2010-02>

<https://www.phpmyadmin.net/security/PMASA-2010-7/>

Solution

Upgrade to phpMyAdmin 3.3.7 or later.

Risk Factor

Medium

VPR Score

3.0

EPSS Score

0.0039

CVSS v2.0 Base Score

4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N)

CVSS v2.0 Temporal Score

3.7 (CVSS2#E:H/RL:OF/RC:C)

References

CVE	CVE-2010-3263
XREF	TRA:TRA-2010-02
XREF	CWE:20

XREF	CWE:74
XREF	CWE:79
XREF	CWE:442
XREF	CWE:629
XREF	CWE:711
XREF	CWE:712
XREF	CWE:722
XREF	CWE:725
XREF	CWE:750
XREF	CWE:751
XREF	CWE:800
XREF	CWE:801
XREF	CWE:809
XREF	CWE:811
XREF	CWE:864
XREF	CWE:900
XREF	CWE:928
XREF	CWE:931
XREF	CWE:990

Plugin Information

Published: 2010/09/08, Modified: 2022/04/11

Plugin Output

192.168.1.4 (tcp/80/www)

```
By making a series of requests, Nessus was able to determine the
following phpMyAdmin installation is vulnerable :
```

```
http://192.168.1.4/phpMyAdmin/
```

51425 (1) - phpMyAdmin error.php BBcode Tag XSS (PMASA-2010-9)

Synopsis

The remote web server hosts a PHP script that is prone to a cross- site scripting attack.

Description

The version of phpMyAdmin fails to validate BBcode tags in user input to the 'error' parameter of the 'error.php' script before using it to generate dynamic HTML.

An attacker may be able to leverage this issue to inject arbitrary HTML or script code into a user's browser to be executed within the security context of the affected site. For example, this could be used to cause a page with arbitrary text and a link to an external site to be displayed.

See Also

<https://www.phpmyadmin.net/security/PMASA-2010-9/>

Solution

Upgrade to phpMyAdmin 3.4.0-beta1 or later.

Risk Factor

Medium

VPR Score

3.8

EPSS Score

0.0823

CVSS v2.0 Base Score

4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N)

CVSS v2.0 Temporal Score

3.7 (CVSS2#E:H/RL:OF/RC:C)

References

BID	45633
CVE	CVE-2010-4480
XREF	EDB-ID:15699

XREF	CWE:20
XREF	CWE:74
XREF	CWE:79
XREF	CWE:442
XREF	CWE:629
XREF	CWE:711
XREF	CWE:712
XREF	CWE:722
XREF	CWE:725
XREF	CWE:750
XREF	CWE:751
XREF	CWE:800
XREF	CWE:801
XREF	CWE:809
XREF	CWE:811
XREF	CWE:864
XREF	CWE:900
XREF	CWE:928
XREF	CWE:931
XREF	CWE:990

Plugin Information

Published: 2011/01/06, Modified: 2022/04/11

Plugin Output

192.168.1.4 (tcp/80/www)

Nessus was able to exploit the issue using the following URL :

```
http://192.168.1.4/phpMyAdmin/error.php?type=phpmyadmin_pmasa_2010_9.nasl&error=%5ba%40https%3a%2f%2fwww.phpmyadmin.net%2fsecurity%2fPMASA-2010-9%2f%40_self%5dClick%20here%5b%2fa%5d
```

26194 (2) - Web Server Transmits Cleartext Credentials

Synopsis

The remote web server might transmit credentials in cleartext.

Description

The remote web server contains several HTML form fields containing an input of type 'password' which transmit their information to a remote web server in cleartext.

An attacker eavesdropping the traffic between web browser and server may obtain logins and passwords of valid users.

Solution

Make sure that every sensitive form transmits content over HTTPS.

Risk Factor

Low

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

References

XREF	CWE:522
XREF	CWE:523
XREF	CWE:718
XREF	CWE:724
XREF	CWE:928
XREF	CWE:930

Plugin Information

Published: 2007/09/28, Modified: 2016/11/29

Plugin Output

192.168.1.4 (tcp/80/www)

```
Page : /phpMyAdmin/  
Destination Page: /phpMyAdmin/index.php  
  
Page : /phpMyAdmin/index.php  
Destination Page: /phpMyAdmin/index.php
```

192.168.1.4 (tcp/8180/www)

Page : /admin/
Destination Page: /admin/j_security_check

Page : /admin/error.jsp
Destination Page: /admin/j_security_check

42057 (2) - Web Server Allows Password Auto-Completion

Synopsis

The 'autocomplete' attribute is not disabled on password fields.

Description

The remote web server contains at least one HTML form field that has an input of type 'password' where 'autocomplete' is not set to 'off'.

While this does not represent a risk to this web server per se, it does mean that users who use the affected forms may have their credentials saved in their browsers, which could in turn lead to a loss of confidentiality if any of them use a shared host or if their machine is compromised at some point.

Solution

Add the attribute 'autocomplete=off' to these fields to prevent browsers from caching credentials.

Risk Factor

Low

Plugin Information

Published: 2009/10/07, Modified: 2023/07/17

Plugin Output

192.168.1.4 (tcp/80/www)

```
Page : /phpMyAdmin/  
Destination Page: /phpMyAdmin/index.php  
  
Page : /phpMyAdmin/index.php  
Destination Page: /phpMyAdmin/index.php
```

192.168.1.4 (tcp/8180/www)

```
Page : /admin/  
Destination Page: /admin/j_security_check  
  
Page : /admin/error.jsp  
Destination Page: /admin/j_security_check
```

34850 (1) - Web Server Uses Basic Authentication Without HTTPS

Synopsis

The remote web server seems to transmit credentials in cleartext.

Description

The remote web server contains web pages that are protected by 'Basic' authentication over cleartext.

An attacker eavesdropping the traffic might obtain logins and passwords of valid users.

Solution

Make sure that HTTP authentication is transmitted over HTTPS.

Risk Factor

Low

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

References

XREF	CWE:319
XREF	CWE:928
XREF	CWE:930
XREF	CWE:934

Plugin Information

Published: 2008/11/21, Modified: 2016/11/29

Plugin Output

192.168.1.4 (tcp/8180/www)

The following web pages use Basic Authentication over an unencrypted channel :

```
/host-manager/html:/ realm="Tomcat Host Manager Application"  
/manager/html:/ realm="Tomcat Manager Application"  
/manager/status:/ realm="Tomcat Manager Application"
```


11219 (25) - Nessus SYN scanner

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2025/07/14

Plugin Output

192.168.1.4 (tcp/21/ftp)

```
Port 21/tcp was found to be open
```

192.168.1.4 (tcp/22/ssh)

```
Port 22/tcp was found to be open
```

192.168.1.4 (tcp/23)

```
Port 23/tcp was found to be open
```

192.168.1.4 (tcp/25/smtp)

```
Port 25/tcp was found to be open
```

192.168.1.4 (tcp/53/dns)

Port 53/tcp was found to be open

192.168.1.4 (tcp/80/www)

Port 80/tcp was found to be open

192.168.1.4 (tcp/111/rpc-portmapper)

Port 111/tcp was found to be open

192.168.1.4 (tcp/139/smb)

Port 139/tcp was found to be open

192.168.1.4 (tcp/445/cifs)

Port 445/tcp was found to be open

192.168.1.4 (tcp/512)

Port 512/tcp was found to be open

192.168.1.4 (tcp/513)

Port 513/tcp was found to be open

192.168.1.4 (tcp/514)

Port 514/tcp was found to be open

192.168.1.4 (tcp/1099)

Port 1099/tcp was found to be open

192.168.1.4 (tcp/1524/wild_shell)

Port 1524/tcp was found to be open

192.168.1.4 (tcp/2049/rpc-nfs)

Port 2049/tcp was found to be open

192.168.1.4 (tcp/2121)

Port 2121/tcp was found to be open

192.168.1.4 (tcp/3306/mysql)

Port 3306/tcp was found to be open

192.168.1.4 (tcp/3632)

Port 3632/tcp was found to be open

192.168.1.4 (tcp/5432/postgresql)

Port 5432/tcp was found to be open

192.168.1.4 (tcp/5900/vnc)

Port 5900/tcp was found to be open

192.168.1.4 (tcp/6000)

Port 6000/tcp was found to be open

192.168.1.4 (tcp/6667/irc)

Port 6667/tcp was found to be open

192.168.1.4 (tcp/8009/ajp13)

Port 8009/tcp was found to be open

192.168.1.4 (tcp/8180/www)

Port 8180/tcp was found to be open

192.168.1.4 (tcp/8787)

Port 8787/tcp was found to be open

10107 (2) - HTTP Server Type and Version

Synopsis

A web server is running on the remote host.

Description

This plugin attempts to determine the type and the version of the remote web server.

Solution

n/a

Risk Factor

None

References

XREF IAVT:0001-T-0931

Plugin Information

Published: 2000/01/04, Modified: 2020/10/30

Plugin Output

192.168.1.4 (tcp/80/www)

```
The remote web server type is :
```

```
Apache/2.2.8 (Ubuntu) DAV/2
```

192.168.1.4 (tcp/8180/www)

```
The remote web server type is :
```

```
Apache-Coyote/1.1
```

10662 (2) - Web mirroring

Synopsis

Nessus can crawl the remote website.

Description

This plugin makes a mirror of the remote website(s) and extracts the list of CGIs that are used by the remote host.

It is suggested that you change the number of pages to mirror in the 'Options' section of the client.

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2001/05/04, Modified: 2025/07/14

Plugin Output

192.168.1.4 (tcp/80/www)

```
Webmirror performed 100 queries in 15s (6.0666 queries per second)
```

```
The following CGIs have been discovered :
```

```
+ CGI : /phpMyAdmin/phpmyadmin.css.php
  Methods : GET
  Argument : js_frame
    Value: right
  Argument : nocache
    Value: 2457687233
  Argument : token
    Value: a0f8530bb6e54d41309973517dce9e7f

+ CGI : /phpMyAdmin/index.php
  Methods : POST
  Argument : db
  Argument : lang
  Argument : pma_password
  Argument : pma_username
  Argument : server
    Value: 1
  Argument : table
  Argument : token
    Value: a0f8530bb6e54d41309973517dce9e7f
```

```

+ CGI : /mutillidae/index.php
  Methods : GET
  Argument : do
    Value: toggle-security
  Argument : page
    Value: notes.php
  Argument : username
    Value: anonymous

+ CGI : /mutillidae/
  Methods : GET
  Argument : page
    Value: source-viewer.php

+ CGI : /rdiff/TWiki/TWikiHistory
  Methods : GET
  Argument : rev1
    Value: 1.8
  Argument : rev2
    Value: 1.7

+ CGI : /view/TWiki/TWikiHistory
  Methods : GET
  Argument : rev
    Value: 1.7

+ CGI : /oops/TWiki/TWikiHistory
  Methods : GET
  Argument : param1
    Value: 1.10
  Argument : template
    Value: oopsrev

+ CGI : /twiki/bin/view/Main/WebHome
  Methods : GET
  Argument : topic

+ CGI : /twiki/bin/search/Main/SearchResult
  Methods : GET
  Argument : search

+ CGI : /twiki/bin/view/Main/WebHome/twiki/bin/edit/Main/WebHome
  Methods : GET
  Argument : t
    Value: 1754075648

+ CGI : /twiki/bin/view/Main/WebHome/twiki/bin/search/Main/SearchResult
  Methods : GET
  Argument : regex
    Value: on
  Argument : scope
    Value: text
  Argument : search
    Value: Web%20*Home%5B%5EA-Za-z%5D

+ CGI : /twiki/bin/view/Main/WebHome/twiki/bin/view/Main/WebHome
  Methods : GET
  Argument : rev
    Value: 1.18

```

```
Argument : skin
Value: print

+ CGI : /twiki/bin/view/Main/WebHome/twiki/bin/rdiff/Main/WebHome
Methods : GET
Argument : rev1
Value: 1.19
Argument : rev2
Value: 1.18

+ CGI : /twiki/bin/view/Main/WebHome/twiki/bin/oops/Main/WebHome
Methods : GET
Argument : param1
Value: 1.20
Argument : ...]
```

192.168.1.4 (tcp/8180/www)

Webmirror performed 551 queries in 113s (4.0876 queries per second)

The following CGIs have been discovered :

```
+ CGI : /jsp-examples/jsp2/el/implicit-objects.jsp
Methods : GET
Argument : foo
Value: bar

+ CGI : /jsp-examples/jsp2/el/functions.jsp
Methods : GET
Argument : foo
Value: JSP+2.0

+ CGI : /admin/j_security_check
Methods : POST
Argument : j_password
Argument : j_username

+ CGI : /jsp-examples/num/numguess.jsp
Methods : GET
Argument : guess

+ CGI : /jsp-examples/error/err.jsp
Methods : GET
Argument : name
Value: audi
Argument : submit
Value: Submit

+ CGI : /jsp-examples/sessions/carts.jsp
Methods : GET
Argument : item
Argument : submit
Value: remove

+ CGI : /jsp-examples/checkbox/checkresult.jsp
Methods : GET
Argument : fruit
Value: melons
```

```
Argument : submit
Value: Submit

+ CGI : /jsp-examples/colors/colrs.jsp
Methods : GET,POST
Argument : action
Value: Hint
Argument : color1
Argument : color2

+ CGI : /jsp-examples/cal/cal1.jsp
Methods : GET
Argument : action
Value: Submit
Argument : email
Argument : name

+ CGI : /servlets-examples/servlet/RequestParamExample
Methods : POST
Argument : firstname
Argument : lastname

+ CGI : /servlets-examples/servlet/CookieExample
Methods : POST
Argument : cookiename
Argument : cookievalue

+ CGI : /servlets-examples/servlet/SessionExample;jsessionid=35FACA277EAA2565A2D9E97EDD93A268
Methods : GET,POST
Argument : dataname
Value: foo
Argument : datavalue
Value: bar
```


11032 (2) - Web Server Directory Enumeration

Synopsis

It is possible to enumerate directories on the web server.

Description

This plugin attempts to determine the presence of various common directories on the remote web server. By sending a request for a directory, the web server response code indicates if it is a valid directory or not.

See Also

<http://projects.webappsec.org/w/page/13246953/Predictable%20Resource%20Location>

Solution

n/a

Risk Factor

None

References

XREF OWASP:OWASP-CM-006

Plugin Information

Published: 2002/06/26, Modified: 2024/06/07

Plugin Output

192.168.1.4 (tcp/80/www)

```
The following directories were discovered:  
/cgi-bin, /doc, /test, /icons, /phpMyAdmin, /twiki/bin
```

```
While this is not, in and of itself, a bug, you should manually inspect  
these directories to ensure that they are in compliance with company  
security standards
```

192.168.1.4 (tcp/8180/www)

```
The following directories were discovered:  
/admin, /jsp-examples, /servlets-examples
```

```
While this is not, in and of itself, a bug, you should manually inspect
```

these directories to ensure that they are in compliance with company security standards

The following directories require authentication:
/host-manager/html, /manager/html

11419 (2) - Web Server Office File Inventory

Synopsis

The remote web server hosts office-related files.

Description

This plugin connects to the remote web server and attempts to find office-related files such as .doc, .ppt, .xls, .pdf etc.

Solution

Make sure that such files do not contain any confidential or otherwise sensitive information and that they are only accessible to those with valid credentials.

Risk Factor

None

Plugin Information

Published: 2003/03/19, Modified: 2022/04/11

Plugin Output

192.168.1.4 (tcp/80/www)

The following office-related files are available on the remote server :

- Adobe Acrobat files (.pdf) :
/mutillidae/documentation/mutillidae-installation-on-xampp-win7.pdf

192.168.1.4 (tcp/8180/www)

The following office-related files are available on the remote server :

- Adobe Acrobat files (.pdf) :
/tomcat-docs/architecture/requestProcess/requestProcess.pdf
/tomcat-docs/architecture/startup/serverStartup.pdf

24260 (2) - HyperText Transfer Protocol (HTTP) Information

Synopsis

Some information about the remote HTTP configuration can be extracted.

Description

This test gives some information about the remote HTTP protocol - the version used, whether HTTP Keep-Alive is enabled, etc...

This test is informational only and does not denote any security problem.

Solution

n/a

Risk Factor	Impact	Control
1. Lack of industry experience	Low	Training and mentorship
2. Limited network	Medium	Networking events and referrals
3. Inconsistent output	High	Regular check-ins and feedback
4. Poor time management	Medium	Time management training
5. Limited resources	Low	Resource allocation and prioritization

None

Plugin Information

Published: 2007/01/30, Modified: 2024/02/26

Plugin Output

192.168.1.4 (tcp/80/www)

```

Response Code : HTTP/1.1 200 OK

Protocol version : HTTP/1.1
HTTP/2 TLS Support: No
HTTP/2 Cleartext Support: No
SSL : no
Keep-Alive : yes
Options allowed : (Not implemented)
Headers :

    Date: Fri, 01 Aug 2025 19:23:13 GMT
    Server: Apache/2.2.8 (Ubuntu) DAV/2
    X-Powered-By: PHP/5.2.4-2ubuntu5.10
    Content-Length: 891
    Keep-Alive: timeout=15, max=100
    Connection: Keep-Alive
    Content-Type: text/html

Response Body :

<html><head><title>Metasploitable2 - Linux</title></head><body>
<pre>
_ _ _ _ _ _ | _ _ _ _ _ _ | _ _ ( ) _ _ _ | _ _ | _ _ | _ _ \
| ' _ ' _ \ / _ \ _ / _ | ' _ \ | / _ \ | _ / _ ' _ \ | / _ \ ) |

```

```

Response Code : HTTP/1.1 200 OK

Protocol version : HTTP/1.1
HTTP/2 TLS Support: No
HTTP/2 Cleartext Support: No
SSL : no
Keep-Alive : yes
Options allowed : (Not implemented)
Headers :

    Date: Fri, 01 Aug 2025 19:23:13 GMT
    Server: Apache/2.2.8 (Ubuntu) DAV/2
    X-Powered-By: PHP/5.2.4-2ubuntu5.10
    Content-Length: 891
    Keep-Alive: timeout=15, max=100
    Connection: Keep-Alive
    Content-Type: text/html

Response Body :

<html><head><title>Metasploitable2 - Linux</title></head><body>
<pre>
_ _ _ _ _ _ | _ _ _ _ _ _ | _ _ ( ) _ _ _ | _ _ | _ _ | _ _ \
| ' _ ' _ \ / _ \ _ / _ | ' _ \ | / _ \ | _ / _ ' _ \ | / _ \ ) |

```

```

Response Code : HTTP/1.1 200 OK

Protocol version : HTTP/1.1
HTTP/2 TLS Support: No
HTTP/2 Cleartext Support: No
SSL : no
Keep-Alive : yes
Options allowed : (Not implemented)
Headers :

    Date: Fri, 01 Aug 2025 19:23:13 GMT
    Server: Apache/2.2.8 (Ubuntu) DAV/2
    X-Powered-By: PHP/5.2.4-2ubuntu5.10
    Content-Length: 891
    Keep-Alive: timeout=15, max=100
    Connection: Keep-Alive
    Content-Type: text/html

Response Body :

<html><head><title>Metasploitable2 - Linux</title></head><body>
<pre>
_ _ _ _ _ _ | _ _ _ _ _ _ | _ _ ( ) _ _ _ | _ _ | _ _ | _ _ \
| ' _ ' _ \ / _ \ _ / _ | ' _ \ | / _ \ | _ / _ ' _ \ | / _ \ ) |

```

```

Response Code : HTTP/1.1 200 OK

Protocol version : HTTP/1.1
HTTP/2 TLS Support: No
HTTP/2 Cleartext Support: No
SSL : no
Keep-Alive : yes
Options allowed : (Not implemented)
Headers :

    Date: Fri, 01 Aug 2025 19:23:13 GMT
    Server: Apache/2.2.8 (Ubuntu) DAV/2
    X-Powered-By: PHP/5.2.4-2ubuntu5.10
    Content-Length: 891
    Keep-Alive: timeout=15, max=100
    Connection: Keep-Alive
    Content-Type: text/html

Response Body :

<html><head><title>Metasploitable2 - Linux</title></head><body>
<pre>
_ _ _ _ _ _ | _ _ _ _ _ _ | _ _ ( ) _ _ _ | _ _ | _ _ | _ _ \
| ' _ ' _ \ / _ \ _ / _ | ' _ \ | / _ \ | _ / _ ' _ \ | / _ \ ) |

```

```

Response Code : HTTP/1.1 200 OK

Protocol version : HTTP/1.1
HTTP/2 TLS Support: No
HTTP/2 Cleartext Support: No
SSL : no
Keep-Alive : yes
Options allowed : (Not implemented)
Headers :

    Date: Fri, 01 Aug 2025 19:23:13 GMT
    Server: Apache/2.2.8 (Ubuntu) DAV/2
    X-Powered-By: PHP/5.2.4-2ubuntu5.10
    Content-Length: 891
    Keep-Alive: timeout=15, max=100
    Connection: Keep-Alive
    Content-Type: text/html

Response Body :

<html><head><title>Metasploitable2 - Linux</title></head><body>
<pre>
_ _ _ _ _ _ | _ _ _ _ _ _ | _ _ ( ) _ _ _ | _ _ | _ _ | _ _ \
| ' _ ' _ \ / _ \ _ / _ | ' _ \ | / _ \ | _ / _ ' _ \ | / _ \ ) |

```



```

/*<![CDATA[*]
  body {
    color: #000000;
    background-color: #FFFFFF;
font-family: Arial, "Times New Roman", Times, serif;
    margin: 10px 0px;
  }

  img {
    border: none;
  }

  a:link, a:visited {
    color: blue
  }

  th {
    font-family: Verdana, "Times New Roman", Times, serif;
    font-size: 110%;
    font-weight: normal;
    font-style: italic;
    background: #D2A41C;
    text-align: left;
  }

  td {
    color: #000000;
font-family: Arial, Helvetica, sans-serif;
  }

  td.men [...]

```

43111 (2) - HTTP Methods Allowed (per directory)

Synopsis

This plugin determines which HTTP methods are allowed on various CGI directories.

Description

By calling the OPTIONS method, it is possible to determine which HTTP methods are allowed on each directory.

The following HTTP methods are considered insecure:

PUT, DELETE, CONNECT, TRACE, HEAD

Many frameworks and languages treat 'HEAD' as a 'GET' request, albeit one without any body in the response. If a security constraint was set on 'GET' requests such that only 'authenticatedUsers' could access GET requests for a particular servlet or resource, it would be bypassed for the 'HEAD' version. This allowed unauthorized blind submission of any privileged GET request.

As this list may be incomplete, the plugin also tests - if 'Thorough tests' are enabled or 'Enable web applications tests' is set to 'yes'

in the scan policy - various known HTTP methods on each directory and considers them as unsupported if it receives a response code of 400, 403, 405, or 501.

Note that the plugin output is only informational and does not necessarily indicate the presence of any security vulnerabilities.

See Also

<http://www.nessus.org/u?d9c03a9a>

<http://www.nessus.org/u?b019cbdb>

[https://www.owasp.org/index.php/Test_HTTP_Methods_\(OTG-CONFIG-006\)](https://www.owasp.org/index.php/Test_HTTP_Methods_(OTG-CONFIG-006))

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2009/12/10, Modified: 2022/04/11

Plugin Output

192.168.1.4 (tcp/80/www)

Based on the response to an OPTIONS request :

- HTTP methods COPY DELETE GET HEAD LOCK MOVE OPTIONS POST PROPFIND PROPPATCH TRACE UNLOCK are allowed on :

/dav

- HTTP methods GET HEAD OPTIONS POST TRACE are allowed on :

/doc
/dvwa/dvwa
/dvwa/dvwa/css
/dvwa/dvwa/images
/dvwa/dvwa/includes
/dvwa/dvwa/includes/DBMS
/dvwa/dvwa/js
/icons
/mutillidae/documentation
/mutillidae/styles
/mutillidae/styles/ddsmoothmenu
/test
/test/testoutput
/twiki

Based on tests of each method :

- HTTP methods ACL BASELINE-CONTROL BCOPY BDELETE BMOVE BPROPFIND BPROPPATCH CHECKIN CHECKOUT COPY DEBUG DELETE GET HEAD INDEX LABEL LOCK MERGE MKACTION MKCOL MKWORKSPACE MOVE NOTIFY OPTIONS ORDERPATCH PATCH POLL POST PROPFIND PROPPATCH PUT REPORT RPC_IN_DATA RPC_OUT_DATA SEARCH SUBSCRIBE TRACE UNCHECKOUT UNLOCK UNSUBSCRIBE UPDATE VERSION-CONTROL X-MS-ENUMATTS are allowed on :

/cgi-bin
/twiki/bin

- HTTP methods COPY DELETE GET HEAD MKCOL MKWORKSPACE MOVE NOTIFY OPTIONS ORDERPATCH PATCH POLL POST PROPFIND PROPPATCH PUT REPORT RPC_IN_DATA RPC_OUT_DATA SEARCH SUBSCRIBE TRACE UNCHECKOUT UNLOCK UNSUBSCRIBE UPDATE VERSION-CONTROL X-MS-ENUMATTS are allowed on :

/dav

- HTTP methods GET HEAD OPTIONS POST TRACE are allowed on :

/
/doc
/dvwa
/dvwa/dvwa
/dvwa/dvwa/css
/dvwa/dvwa/images
/dvwa/dvwa/includes
/dvwa/dvwa/includes/DBMS
/dvwa/dvwa/js
/icons
/mutillidae
/mutillidae/documentation
/mutillidae/styles
/mutillidae/styles/ddsmoothmenu
/phpMyAdmin
/test
/test/testoutput
/twiki

- Invalid/unknown HTTP methods are allowed on :

/cgi-bin
/dav

192.168.1.4 (tcp/8180/www)

Based on the response to an OPTIONS request :

- HTTP methods DELETE HEAD OPTIONS POST PUT TRACE GET
are allowed on :

```
/admin/error.jsp
/host-manager
/jsp-examples
/jsp-examples/cal
/jsp-examples/checkbox
/jsp-examples/colors
/jsp-examples/dates
/jsp-examples/error
/jsp-examples/forward
/jsp-examples/include
/jsp-examples/jsp2
/jsp-examples/jsp2/el
/jsp-examples/jsp2/jspattribute
/jsp-examples/jsp2/jsp
/jsp-examples/jsp2/misc
/servlets-examples
```

Based on tests of each method :

- HTTP methods GET HEAD OPTIONS POST are allowed on :

```
/
/admin
/admin/error.jsp
/host-manager
/jsp-examples
/jsp-examples/cal
/jsp-examples/checkbox
/jsp-examples/colors
/jsp-examples/dates
/jsp-examples/error
/jsp-examples/forward
/jsp-examples/include
/jsp-examples/jsp2
/jsp-examples/jsp2/el
/jsp-examples/jsp2/jspattribute
/jsp-examples/jsp2/jsp
/jsp-examples/jsp2/misc
/servlets-examples
```

49704 (2) - External URLs

Synopsis

Links to external sites were gathered.

Description

Nessus gathered HREF links to external sites by crawling the remote web server.

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2010/10/04, Modified: 2011/08/19

Plugin Output

192.168.1.4 (tcp/80/www)

```
104 external URLs were gathered on this web server :
URL... - Seen on...

http://TWiki.org/ - /twiki/bin/view/Main/WebHome
http://TWiki.org/cgi-bin/view/Main/TWikiAdminGroup - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/Main/TWikiUsers - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/AlWilliams - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/AndreaSterbini - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/BookView - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/ChangePassword - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/ChristopheVermeulen - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/ColasNahaboo - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/CrisBailiff - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/DavidWarman - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/DontNotify - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/FileAttachment - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/FormattedSearch - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/HaroldGottschalk - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/InterwikiPlugin - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/JohnAltstadt - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/JohnTalintyre - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/KevinKinnell - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/KlausWriessnegger - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/ManagingTopics - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/ManagingWebs - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/ManpreetSingh - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/NewUserTemplate - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/NicholasLee - /twiki/TWikiHistory.html
```

```
http://TWiki.org/cgi- [...]
```

192.168.1.4 (tcp/8180/www)

```
112 external URLs were gathered on this web server :  
URL... - Seen on...
```

```
http://192.168.1.4:8180/admin/error.jsp - /admin/j_security_check  
http://192.168.1.4:8180/admin/login.jsp - /admin/  
http://ant.apache.org - /tomcat-docs/manager-howto.html  
http://ant.apache.org/bindownload.cgi - /tomcat-docs/building.html  
http://apache.apache.org/ - /tomcat-docs/appdev/index.html  
http://apr.apache.org/ - /tomcat-docs/apr.html  
http://httpd.apache.org/docs/2.2/mod/mod_proxy_ajp.html - /tomcat-docs/config/ajp.html  
http://httpd.apache.org/docs/2.2/mod/mod_ssl.html#sslcertificatefile - /tomcat-docs/apr.html  
http://httpd.apache.org/docs/2.2/mod/mod_ssl.html#sslcertificatepath - /tomcat-docs/apr.html  
http://httpd.apache.org/docs/2.2/mod/mod_ssl.html#sslcarevocationfile - /tomcat-docs/apr.html  
http://httpd.apache.org/docs/2.2/mod/mod_ssl.html#sslcarevocationpath - /tomcat-docs/apr.html  
http://httpd.apache.org/docs/2.2/mod/mod_ssl.html#sslcertificatechainfile - /tomcat-docs/apr.html  
http://httpd.apache.org/docs/howto/ssi.html#basicssidirectives - /tomcat-docs/ssi-howto.html  
http://issues.apache.org/bugzilla/buglist.cgi?  
bug_status=UNCONFIRMED&bug_status=NEW&bug_status=ASSIGNED&bug_status=REOPENED&bug_status=RESOLVED&resolution=LATER  
&bugidtype=include&product=Tomcat+5&cmdtype=doit&order=Importance - /  
http://issues.apache.org/bugzilla/show_bug.cgi?id=22679 - /tomcat-docs/ssl-howto.html  
http://issues.apache.org/bugzilla/show_bug.cgi?id=34643 - /tomcat-docs/ssl-howto.html  
http://issues.apache.org/bugzilla/show_bug.cgi?id=37668 - /tomcat-docs/config/context.html  
http://issues.apache.org/bugzilla/show_bug.cgi?id=38217 - /tomcat-docs/ssl-howto.html  
http://issues.apache.org/bugzilla/show_bug.cgi?id=39013 - /tomcat-docs/config/context.html  
http://jakarta.apache.org/commons - /tomcat-docs/jndi-resources-howto.html  
http://jakarta.apache.org/commons/dbcp/configuration.html - /tomcat-docs/jndi-datasource-examples-  
howto [...]
```

49705 (2) - Web Server Harvested Email Addresses

Synopsis

Email addresses were harvested from the web server.

Description

Nessus harvested HREF mailto: links and extracted email addresses by crawling the remote web server.

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2010/10/04, Modified: 2018/05/24

Plugin Output

192.168.1.4 (tcp/80/www)

The following email address has been gathered :

- 'SomeWikiName@somewhere.test', referenced from :
/twiki/TWikiHistory.html

192.168.1.4 (tcp/8180/www)

The following email addresses have been gathered :

- 'craigmcc@apache.org', referenced from :
/tomcat-docs/appdev/printer/index.html
/tomcat-docs/appdev/index.html
/tomcat-docs/appdev/
/tomcat-docs/appdev/printer/
- 'yoavs@apache.org', referenced from :
/tomcat-docs/architecture/printer/
/tomcat-docs/architecture/index.html
/tomcat-docs/architecture/printer/index.html
/tomcat-docs/architecture/
- 'users@tomcat.apache.org', referenced from :

```
/
- 'jfarcaud@apache.org', referenced from :
  /tomcat-docs/architecture/
  /tomcat-docs/architecture/printer/index.html
  /tomcat-docs/architecture/printer/
  /tomcat-docs/architecture/index.html
- 'fhanik@apache.org', referenced from :
  /tomcat-docs/architecture/printer/index.html
  /tomcat-docs/architecture/
  /tomcat-docs/architecture/printer/
  /tomcat-docs/architecture/index.html
- 'dev@tomcat.apache.org', referenced from :
  /
```

50344 (2) - Missing or Permissive Content-Security-Policy frame-ancestors HTTP Response Header

Synopsis

The remote web server does not take steps to mitigate a class of web application vulnerabilities.

Description

The remote web server in some responses sets a permissive Content-Security-Policy (CSP) frame-ancestors response header or does not set one at all.

The CSP frame-ancestors header has been proposed by the W3C Web Application Security Working Group as a way to mitigate cross-site scripting and clickjacking attacks.

See Also

<http://www.nessus.org/u?55aa8f57>

<http://www.nessus.org/u?07cc2a06>

<https://content-security-policy.com/>

<https://www.w3.org/TR/CSP2/>

Solution

Set a non-permissive Content-Security-Policy frame-ancestors header for all requested resources.

Risk Factor

None

Plugin Information

Published: 2010/10/26, Modified: 2021/01/19

Plugin Output

192.168.1.4 (tcp/80/www)

The following pages do not set a Content-Security-Policy frame-ancestors response header or set a permissive policy:

- <http://192.168.1.4/>
- <http://192.168.1.4/dav/>
- <http://192.168.1.4/dvwa/dvwa/>
- <http://192.168.1.4/dvwa/dvwa/css/>
- <http://192.168.1.4/dvwa/dvwa/images/>
- <http://192.168.1.4/dvwa/dvwa/includes/>
- <http://192.168.1.4/dvwa/dvwa/includes/DBMS/>
- <http://192.168.1.4/dvwa/dvwa/includes/DBMS/DBMS.php>
- <http://192.168.1.4/dvwa/dvwa/includes/DBMS/MySQL.php>

- <http://192.168.1.4/dvwa/dvwa/includes/dvwaPage.inc.php>
- <http://192.168.1.4/dvwa/dvwa/includes/dvwaPhpIds.inc.php>
- <http://192.168.1.4/dvwa/dvwa/js/>
- <http://192.168.1.4/dvwa/login.php>
- <http://192.168.1.4/mutillidae/>
- <http://192.168.1.4/mutillidae/documentation/>
- <http://192.168.1.4/mutillidae/documentation/how-to-access-Mutillidae-over-Virtual-Box-network.php>
- <http://192.168.1.4/mutillidae/documentation/vulnerabilities.php>
- <http://192.168.1.4/mutillidae/framer.html>
- <http://192.168.1.4/mutillidae/index.php>
- <http://192.168.1.4/mutillidae/set-up-database.php>
- <http://192.168.1.4/mutillidae/styles/>
- <http://192.168.1.4/mutillidae/styles/ddsmoothmenu/>
- <http://192.168.1.4/phpMyAdmin/>
- <http://192.168.1.4/phpMyAdmin/index.php>
- <http://192.168.1.4/test/>
- <http://192.168.1.4/test/testoutput/>
- <http://192.168.1.4/twiki/>
- <http://192.168.1.4/twiki/TWikiHistory.html>
- <http://192.168.1.4/twiki/bin/oops>
- <http://192.168.1.4/twiki/bin/oops/Main>
- <http://192.168.1.4/twiki/bin/oops/Main/WebHomemailto%3Awebmasteryour>
- <http://192.168.1.4/twiki/bin/oops/Main/WebHomemailto%3Awebmasteryour/company>
- <http://192.168.1.4/twiki/bin/search>
- <http://192.168.1.4/twiki/bin/search/Main>
- <http://192.168.1.4/twiki/bin/search/Main/SearchResult>
- <http://192.168.1.4/twiki/bin/view>
- <http://192.168.1.4/twiki/bin/view/Main>
- <http://192.168.1.4/twiki/bin/view/Main/WebHome>

192.168.1.4 (tcp/8180/www)

The following pages do not set a Content-Security-Policy frame-ancestors response header or set a permissive policy:

- <http://192.168.1.4:8180/>
- <http://192.168.1.4:8180/admin/>
- <http://192.168.1.4:8180/admin/error.jsp>
- http://192.168.1.4:8180/admin/j_security_check
- <http://192.168.1.4:8180/jsp-examples/>
- <http://192.168.1.4:8180/jsp-examples/cal/Entries.java.html>
- <http://192.168.1.4:8180/jsp-examples/cal/Entry.java.html>
- <http://192.168.1.4:8180/jsp-examples/cal/TableBean.java.html>
- <http://192.168.1.4:8180/jsp-examples/cal/call.jsp>
- <http://192.168.1.4:8180/jsp-examples/cal/call.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/cal/cal2.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/cal/calendar.html>
- <http://192.168.1.4:8180/jsp-examples/cal/login.html>
- <http://192.168.1.4:8180/jsp-examples/checkbox/CheckTest.html>
- <http://192.168.1.4:8180/jsp-examples/checkbox/check.html>
- <http://192.168.1.4:8180/jsp-examples/checkbox/checkresult.jsp>
- <http://192.168.1.4:8180/jsp-examples/checkbox/checkresult.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/checkbox/cresult.html>
- <http://192.168.1.4:8180/jsp-examples/colors/ColorGameBean.html>
- <http://192.168.1.4:8180/jsp-examples/colors/clr.html>
- <http://192.168.1.4:8180/jsp-examples/colors/colors.html>
- <http://192.168.1.4:8180/jsp-examples/colors/colrs.jsp>
- <http://192.168.1.4:8180/jsp-examples/colors/colrs.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/dates/date.html>
- <http://192.168.1.4:8180/jsp-examples/dates/date.jsp>
- <http://192.168.1.4:8180/jsp-examples/dates/date.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/error/er.html>
- <http://192.168.1.4:8180/jsp-examples/error/err.jsp>
- <http://192.168.1.4:8180/jsp-examples/error/err.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/error/error.html>
- <http://192.168.1.4:8180/jsp-examples/forward/forward.jsp>

- `http://192.168.1.4:8180/jsp-examples/forward/forward.jsp.html`
- `http://192.168.1.4:8180/jsp-examples/forward/fwd.html`
- `http://192.168.1.4:8180/jsp-exa [...]`

50345 (2) - Missing or Permissive X-Frame-Options HTTP Response Header

Synopsis

The remote web server does not take steps to mitigate a class of web application vulnerabilities.

Description

The remote web server in some responses sets a permissive X-Frame-Options response header or does not set one at all.

The X-Frame-Options header has been proposed by Microsoft as a way to mitigate clickjacking attacks and is currently supported by all major browser vendors

See Also

<https://en.wikipedia.org/wiki/Clickjacking>

<http://www.nessus.org/u?399b1f56>

Solution

Set a properly configured X-Frame-Options header for all requested resources.

Risk Factor

None

Plugin Information

Published: 2010/10/26, Modified: 2021/01/19

Plugin Output

192.168.1.4 (tcp/80/www)

The following pages do not set a X-Frame-Options response header or set a permissive policy:

- http://192.168.1.4/
- http://192.168.1.4/dav/
- http://192.168.1.4/dvwa/dvwa/
- http://192.168.1.4/dvwa/dvwa/css/
- http://192.168.1.4/dvwa/dvwa/images/
- http://192.168.1.4/dvwa/dvwa/includes/
- http://192.168.1.4/dvwa/dvwa/includes/DBMS/
- http://192.168.1.4/dvwa/dvwa/includes/DBMS/DBMS.php
- http://192.168.1.4/dvwa/dvwa/includes/DBMS/MySQL.php
- http://192.168.1.4/dvwa/dvwa/includes/dvwaPage.inc.php
- http://192.168.1.4/dvwa/dvwa/includes/dvwaPhpIds.inc.php
- http://192.168.1.4/dvwa/dvwa/js/
- http://192.168.1.4/dvwa/login.php
- http://192.168.1.4/mutillidae/
- http://192.168.1.4/mutillidae/documentation/

- <http://192.168.1.4/mutillidae/documentation/how-to-access-Mutillidae-over-Virtual-Box-network.php>
- <http://192.168.1.4/mutillidae/documentation/vulnerabilities.php>
- <http://192.168.1.4/mutillidae/framer.html>
- <http://192.168.1.4/mutillidae/index.php>
- <http://192.168.1.4/mutillidae/set-up-database.php>
- <http://192.168.1.4/mutillidae/styles/>
- <http://192.168.1.4/mutillidae/styles/ddsmoothmenu/>
- <http://192.168.1.4/phpMyAdmin/>
- <http://192.168.1.4/phpMyAdmin/index.php>
- <http://192.168.1.4/test/>
- <http://192.168.1.4/test/testoutput/>
- <http://192.168.1.4/twiki/>
- <http://192.168.1.4/twiki/TWikiHistory.html>
- <http://192.168.1.4/twiki/bin/oops>
- <http://192.168.1.4/twiki/bin/oops/Main>
- <http://192.168.1.4/twiki/bin/oops/Main/WebHomemailto%3Awebmasteryour>
- <http://192.168.1.4/twiki/bin/oops/Main/WebHomemailto%3Awebmasteryour/company>
- <http://192.168.1.4/twiki/bin/search>
- <http://192.168.1.4/twiki/bin/search/Main>
- <http://192.168.1.4/twiki/bin/search/Main/SearchResult>
- <http://192.168.1.4/twiki/bin/view>
- <http://192.168.1.4/twiki/bin/view/Main>
- <http://192.168.1.4/twiki/bin/view/Main/WebHome>

192.168.1.4 (tcp/8180/www)

The following pages do not set a X-Frame-Options response header or set a permissive policy:

- <http://192.168.1.4:8180/>
- <http://192.168.1.4:8180/admin/>
- <http://192.168.1.4:8180/admin/error.jsp>
- http://192.168.1.4:8180/admin/j_security_check
- <http://192.168.1.4:8180/jsp-examples/>
- <http://192.168.1.4:8180/jsp-examples/cal/Entries.java.html>
- <http://192.168.1.4:8180/jsp-examples/cal/Entry.java.html>
- <http://192.168.1.4:8180/jsp-examples/cal/TableBean.java.html>
- <http://192.168.1.4:8180/jsp-examples/cal/cal1.jsp>
- <http://192.168.1.4:8180/jsp-examples/cal/cal1.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/cal/cal2.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/cal/calendar.html>
- <http://192.168.1.4:8180/jsp-examples/cal/login.html>
- <http://192.168.1.4:8180/jsp-examples/checkbox/CheckTest.html>
- <http://192.168.1.4:8180/jsp-examples/checkbox/check.html>
- <http://192.168.1.4:8180/jsp-examples/checkbox/checkresult.jsp>
- <http://192.168.1.4:8180/jsp-examples/checkbox/checkresult.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/checkbox/cresult.html>
- <http://192.168.1.4:8180/jsp-examples/colors/ColorGameBean.html>
- <http://192.168.1.4:8180/jsp-examples/colors/clr.html>
- <http://192.168.1.4:8180/jsp-examples/colors/colors.html>
- <http://192.168.1.4:8180/jsp-examples/colors/colrs.jsp>
- <http://192.168.1.4:8180/jsp-examples/colors/colrs.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/dates/date.html>
- <http://192.168.1.4:8180/jsp-examples/dates/date.jsp>
- <http://192.168.1.4:8180/jsp-examples/dates/date.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/error/er.html>
- <http://192.168.1.4:8180/jsp-examples/error/err.jsp>
- <http://192.168.1.4:8180/jsp-examples/error/err.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/error/error.html>
- <http://192.168.1.4:8180/jsp-examples/forward/forward.jsp>
- <http://192.168.1.4:8180/jsp-examples/forward/forward.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/forward/fwd.html>
- <http://192.168.1.4:8180/jsp-examples/include/inc.html>
- [...]

85601 (2) - Web Application Cookies Not Marked HttpOnly

Synopsis

HTTP session cookies might be vulnerable to cross-site scripting attacks.

Description

The remote web application sets various cookies throughout a user's unauthenticated and authenticated session. However, one or more of those cookies are not marked 'HttpOnly', meaning that a malicious client-side script, such as JavaScript, could read them. The HttpOnly flag is a security mechanism to protect against cross-site scripting attacks, which was proposed by Microsoft and initially implemented in Internet Explorer. All modern browsers now support it.

Note that this plugin detects all general cookies missing the HttpOnly cookie flag, whereas plugin 48432 (Web Application Session Cookies Not Marked HttpOnly) will only detect session cookies from an authenticated session missing the HttpOnly cookie flag.

See Also

<https://www.owasp.org/index.php/HttpOnly>

Solution

Each cookie should be carefully reviewed to determine if it contains sensitive data or is relied upon for a security decision.

If possible, add the 'HttpOnly' attribute to all session cookies and any cookies containing sensitive data.

Risk Factor

None

References

XREF	CWE:20
XREF	CWE:74
XREF	CWE:79
XREF	CWE:442
XREF	CWE:629
XREF	CWE:711
XREF	CWE:712
XREF	CWE:722
XREF	CWE:725
XREF	CWE:750
XREF	CWE:751
XREF	CWE:800

XREF	CWE:801
XREF	CWE:809
XREF	CWE:811
XREF	CWE:864
XREF	CWE:900
XREF	CWE:928
XREF	CWE:931
XREF	CWE:990

Plugin Information

Published: 2015/08/24, Modified: 2015/08/24

Plugin Output

192.168.1.4 (tcp/80/www)

The following cookies do not set the HttpOnly cookie flag :

Name : JSESSIONID
Path : /admin
Value : 47FF6380D75B2152AC8F1B07DF0CF868
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

Name : JSESSIONID
Path : /jsp-examples
Value : 34F62508FFE925CDD0DF0AEB4246BC75
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

Name : PHPSESSID
Path : /
Value : 85a54c35a81cbb0bcf037c91eadb7496
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

Name : JSESSIONID
Path : /servlets-examples
Value : 35FACA277EAA2565A2D9E97EDD93A268
Domain :
Version : 1

```
Expires :  
Comment :  
Secure : 0  
Httponly : 0  
Port :
```

```
Name : security  
Path : /  
Value : high  
Domain :  
Version : 1  
Expires :  
Comment :  
Secure : 0  
Httponly : 0  
Port :
```

192.168.1.4 (tcp/8180/www)

The following cookies do not set the HttpOnly cookie flag :

```
Name : JSESSIONID  
Path : /admin  
Value : 47FF6380D75B2152AC8F1B07DF0CF868  
Domain :  
Version : 1  
Expires :  
Comment :  
Secure : 0  
Httponly : 0  
Port :
```

```
Name : JSESSIONID  
Path : /jsp-examples  
Value : 34F62508FFE925CDD0DF0AEB4246BC75  
Domain :  
Version : 1  
Expires :  
Comment :  
Secure : 0  
Httponly : 0  
Port :
```

```
Name : PHPSESSID  
Path : /  
Value : 85a54c35a81cbb0bcf037c91eadb7496  
Domain :  
Version : 1  
Expires :  
Comment :  
Secure : 0  
Httponly : 0  
Port :
```

```
Name : JSESSIONID  
Path : /servlets-examples  
Value : 35FACA277EAA2565A2D9E97EDD93A268  
Domain :  
Version : 1  
Expires :  
Comment :  
Secure : 0
```

Httponly : 0
Port :

Name : security
Path : /
Value : high
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

85602 (2) - Web Application Cookies Not Marked Secure

Synopsis

HTTP session cookies might be transmitted in cleartext.

Description

The remote web application sets various cookies throughout a user's unauthenticated and authenticated session. However, there are instances where the application is running over unencrypted HTTP or the cookies are not marked 'secure', meaning the browser could send them back over an unencrypted link under certain circumstances. As a result, it may be possible for a remote attacker to intercept these cookies.

Note that this plugin detects all general cookies missing the 'secure' cookie flag, whereas plugin 49218 (Web Application Session Cookies Not Marked Secure) will only detect session cookies from an authenticated session missing the secure cookie flag.

See Also

<https://www.owasp.org/index.php/SecureFlag>

Solution

Each cookie should be carefully reviewed to determine if it contains sensitive data or is relied upon for a security decision.

If possible, ensure all communication occurs over an encrypted channel and add the 'secure' attribute to all session cookies or any cookies containing sensitive data.

Risk Factor

None

References

XREF	CWE:522
XREF	CWE:718
XREF	CWE:724
XREF	CWE:928
XREF	CWE:930

Plugin Information

Published: 2015/08/24, Modified: 2015/08/24

Plugin Output

The following cookies do not set the secure cookie flag :

Name : JSESSIONID
Path : /admin
Value : 47FF6380D75B2152AC8F1B07DF0CF868
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

Name : pma_theme
Path : /phpMyAdmin/
Value : original
Domain :
Version : 1
Expires : Sun, 31-Aug-2025 19:14:02 GMT
Comment :
Secure : 0
Httponly : 1
Port :

Name : pma_fontsize
Path : /phpMyAdmin/
Value : 82%25
Domain :
Version : 1
Expires : Sun, 31-Aug-2025 19:14:02 GMT
Comment :
Secure : 0
Httponly : 1
Port :

Name : JSESSIONID
Path : /jsp-examples
Value : 34F62508FFE925CDD0DF0AEB4246BC75
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

Name : PHPSESSID
Path : /
Value : 85a54c35a81cbb0bcf037c91eadb7496
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

Name : phpMyAdmin
Path : /phpMyAdmin/
Value : d369c6406f8ad162125b9860ed4fed2029a45069
Domain :


```
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 1
Port :

Name : pma_lang
Path : /phpMyAdmin/
Value : en-utf-8
Domain :
Version : 1
Expires : Sun, 31-Aug-2025 19:14:02 GMT
Comment :
Secure : 0
Httponly : 1
Port :

Name : pma_charset
Path : /phpMyAdmin/
Value : utf-8
Domain :
Version : 1
Expires : Sun, 31-Aug-2025 19:14:02 GMT
Comment :
Secure : 0
Httponly : 1
Port :

Name : JSESSIONID
Path : /servlets-examples
Value : 35FACA277EAA2565A2D9E97EDD93A268
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

Name : security
Path : /
Value : high
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :
```

192.168.1.4 (tcp/8180/www)

The following cookies do not set the secure cookie flag :

```
Name : JSESSIONID
Path : /admin
Value : 47FF6380D75B2152AC8F1B07DF0CF868
Domain :
Version : 1
Expires :
Comment :
```

Secure : 0
Httponly : 0
Port :

Name : pma_theme
Path : /phpMyAdmin/
Value : original
Domain :
Version : 1
Expires : Sun, 31-Aug-2025 19:14:02 GMT
Comment :
Secure : 0
Httponly : 1
Port :

Name : pma_fontsize
Path : /phpMyAdmin/
Value : 82%25
Domain :
Version : 1
Expires : Sun, 31-Aug-2025 19:14:02 GMT
Comment :
Secure : 0
Httponly : 1
Port :

Name : JSESSIONID
Path : /jsp-examples
Value : 34F62508FFE925CDD0DF0AEB4246BC75
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

Name : PHPSESSID
Path : /
Value : 85a54c35a81cbb0bcf037c91eadb7496
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

Name : phpMyAdmin
Path : /phpMyAdmin/
Value : d369c6406f8ad162125b9860ed4fed2029a45069
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 1
Port :

Name : pma_lang
Path : /phpMyAdmin/
Value : en-utf-8
Domain :
Version : 1

Expires : Sun, 31-Aug-2025 19:14:02 GMT
Comment :
Secure : 0
Httponly : 1
Port :

Name : pma_charset
Path : /phpMyAdmin/
Value : utf-8
Domain :
Version : 1
Expires : Sun, 31-Aug-2025 19:14:02 GMT
Comment :
Secure : 0
Httponly : 1
Port :

Name : JSESSIONID
Path : /servlets-examples
Value : 35FACA277EAA2565A2D9E97EDD93A268
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

Name : security
Path : /
Value : high
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

91815 (2) - Web Application Sitemap

Synopsis

The remote web server hosts linkable content that can be crawled by Nessus.

Description

The remote web server contains linkable content that can be used to gather information about a target.

See Also

<http://www.nessus.org/u?5496c8d9>

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2016/06/24, Modified: 2016/06/24

Plugin Output

192.168.1.4 (tcp/80/www)

The following sitemap was created from crawling linkable content on the target host :

- <http://192.168.1.4/>
- <http://192.168.1.4/dav/>
- <http://192.168.1.4/dvwa/dvwa/>
- <http://192.168.1.4/dvwa/dvwa/css/>
- <http://192.168.1.4/dvwa/dvwa/css/help.css>
- <http://192.168.1.4/dvwa/dvwa/css/login.css>
- <http://192.168.1.4/dvwa/dvwa/css/main.css>
- <http://192.168.1.4/dvwa/dvwa/css/source.css>
- <http://192.168.1.4/dvwa/dvwa/images/>
- <http://192.168.1.4/dvwa/dvwa/images/RandomStorm.png>
- <http://192.168.1.4/dvwa/dvwa/images/dollar.png>
- <http://192.168.1.4/dvwa/dvwa/images/lock.png>
- http://192.168.1.4/dvwa/dvwa/images/login_logo.png
- <http://192.168.1.4/dvwa/dvwa/images/logo.png>
- <http://192.168.1.4/dvwa/dvwa/images/spanner.png>
- <http://192.168.1.4/dvwa/dvwa/images/warning.png>
- <http://192.168.1.4/dvwa/dvwa/includes/>
- <http://192.168.1.4/dvwa/dvwa/includes/DBMS/>
- <http://192.168.1.4/dvwa/dvwa/includes/DBMS/DBMS.php>
- <http://192.168.1.4/dvwa/dvwa/includes/DBMS/MySQL.php>
- <http://192.168.1.4/dvwa/dvwa/includes/dvwaPage.inc.php>

- <http://192.168.1.4/dvwa/dvwa/includes/dvwaPhpIds.inc.php>
- <http://192.168.1.4/dvwa/dvwa/js/>
- <http://192.168.1.4/dvwa/dvwa/js/dvwaPage.js>
- <http://192.168.1.4/dvwa/login.php>
- <http://192.168.1.4/mutillidae/>
- <http://192.168.1.4/mutillidae/documentation/>
- <http://192.168.1.4/mutillidae/documentation/Mutillidae-Test-Scripts.txt>
- <http://192.168.1.4/mutillidae/documentation/how-to-access-Mutillidae-over-Virtual-Box-network.php>
- <http://192.168.1.4/mutillidae/documentation/mutillidae-installation-on-xampp-win7.pdf>
- <http://192.168.1.4/mutillidae/documentation/sqlmap-help.txt>
- <http://192.168.1.4/mutillidae/documentation/vulnerabilities.php>
- <http://192.168.1.4/mutillidae/favicon.ico>
- <http://192.168.1.4/mutillidae/framer.html>
- <http://192.168.1.4/mutillidae/index.php>
- <http://192.168.1.4/mutillidae/set-up-database.php>
- <http://192.168.1.4/mutillidae/styles/>
- <http://192.168.1.4/mutillidae/styles/ddsmoothmenu/>
- <http://192.168.1.4/muti> [...]

192.168.1.4 (tcp/8180/www)

The following sitemap was created from crawling linkable content on the target host :

- <http://192.168.1.4:8180/>
- <http://192.168.1.4:8180/RELEASE-NOTES.txt>
- <http://192.168.1.4:8180/admin/>
- <http://192.168.1.4:8180/admin/error.jsp>
- http://192.168.1.4:8180/admin/j_security_check
- <http://192.168.1.4:8180/jsp-examples/>
- <http://192.168.1.4:8180/jsp-examples/cal/Entries.java.html>
- <http://192.168.1.4:8180/jsp-examples/cal/Entry.java.html>
- <http://192.168.1.4:8180/jsp-examples/cal/TableBean.java.html>
- <http://192.168.1.4:8180/jsp-examples/cal/cal1.jsp>
- <http://192.168.1.4:8180/jsp-examples/cal/cal1.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/cal/cal2.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/cal/calendar.html>
- <http://192.168.1.4:8180/jsp-examples/cal/login.html>
- <http://192.168.1.4:8180/jsp-examples/checkbox/CheckTest.html>
- <http://192.168.1.4:8180/jsp-examples/checkbox/check.html>
- <http://192.168.1.4:8180/jsp-examples/checkbox/checkresult.jsp>
- <http://192.168.1.4:8180/jsp-examples/checkbox/checkresult.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/checkbox/cresult.html>
- <http://192.168.1.4:8180/jsp-examples/colors/ColorGameBean.html>
- <http://192.168.1.4:8180/jsp-examples/colors/clr.html>
- <http://192.168.1.4:8180/jsp-examples/colors/colors.html>
- <http://192.168.1.4:8180/jsp-examples/colors/colrs.jsp>
- <http://192.168.1.4:8180/jsp-examples/colors/colrs.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/dates/date.html>
- <http://192.168.1.4:8180/jsp-examples/dates/date.jsp>
- <http://192.168.1.4:8180/jsp-examples/dates/date.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/error/er.html>
- <http://192.168.1.4:8180/jsp-examples/error/err.jsp>
- <http://192.168.1.4:8180/jsp-examples/error/err.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/error/error.html>
- <http://192.168.1.4:8180/jsp-examples/forward/forward.jsp>
- <http://192.168.1.4:8180/jsp-examples/forward/forward.jsp.html>
- <http://192.168.1.4:8180/jsp-examples/forward/fwd.html>
- <http://192.168.1> [...]

100669 (2) - Web Application Cookies Are Expired

Synopsis

HTTP cookies have an 'Expires' attribute that is set with a past date or time.

Description

The remote web application sets various cookies throughout a user's unauthenticated and authenticated session. However, Nessus has detected that one or more of the cookies have an 'Expires' attribute that is set with a past date or time, meaning that these cookies will be removed by the browser.

See Also

<https://tools.ietf.org/html/rfc6265>

Solution

Each cookie should be carefully reviewed to determine if it contains sensitive data or is relied upon for a security decision.

If needed, set an expiration date in the future so the cookie will persist or remove the Expires cookie attribute altogether to convert the cookie to a session cookie.

Risk Factor

None

Plugin Information

Published: 2017/06/07, Modified: 2021/12/20

Plugin Output

192.168.1.4 (tcp/80/www)

The following cookies are expired :

Name : pma_fontsize
Path : /phpMyAdmin/
Value : deleted
Domain :
Version : 1
Expires : Thu, 01-Aug-2024 19:25:12 GMT
Comment :
Secure : 0
Httponly : 0
Port :

Name : pma_collation_connection
Path : /phpMyAdmin/

```
Value : deleted
Domain :
Version : 1
Expires : Thu, 01-Aug-2024 19:25:56 GMT
Comment :
Secure : 0
Httponly : 1
Port :
```

```
Name : pma_theme
Path : /phpMyAdmin/
Value : deleted
Domain :
Version : 1
Expires : Thu, 01-Aug-2024 19:24:53 GMT
Comment :
Secure : 0
Httponly : 0
Port :
```

192.168.1.4 (tcp/8180/www)

The following cookies are expired :

```
Name : pma_fontsize
Path : /phpMyAdmin/
Value : deleted
Domain :
Version : 1
Expires : Thu, 01-Aug-2024 19:25:12 GMT
Comment :
Secure : 0
Httponly : 0
Port :
```

```
Name : pma_collation_connection
Path : /phpMyAdmin/
Value : deleted
Domain :
Version : 1
Expires : Thu, 01-Aug-2024 19:25:56 GMT
Comment :
Secure : 0
Httponly : 1
Port :
```

```
Name : pma_theme
Path : /phpMyAdmin/
Value : deleted
Domain :
Version : 1
Expires : Thu, 01-Aug-2024 19:24:53 GMT
Comment :
Secure : 0
Httponly : 0
Port :
```

11422 (1) - Web Server Unconfigured - Default Install Page Present

Synopsis

The remote web server is not configured or is improperly configured.

Description

The remote web server uses its default welcome page. Therefore, it's probable that this server is not used at all or is serving content that is meant to be hidden.

Solution

Disable this service if you do not use it.

Risk Factor

None

Plugin Information

Published: 2003/03/20, Modified: 2018/08/15

Plugin Output

192.168.1.4 (tcp/8180/www)

The default welcome page is from Tomcat.

11424 (1) - WebDAV Detection

Synopsis

The remote server is running with WebDAV enabled.

Description

WebDAV is an industry standard extension to the HTTP specification.

It adds a capability for authorized users to remotely add and manage the content of a web server.

If you do not use this extension, you should disable it.

Solution

<http://support.microsoft.com/default.aspx?kbid=241520>

Risk Factor

None

Plugin Information

Published: 2003/03/20, Modified: 2011/03/14

Plugin Output

192.168.1.4 (tcp/80/www)

17219 (1) - phpMyAdmin Detection

Synopsis

The remote web server hosts a database management application written in PHP.

Description

The remote host is running phpMyAdmin, a web-based MySQL administration tool written in PHP.

See Also

<https://www.phpmyadmin.net/>

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2005/02/25, Modified: 2022/06/01

Plugin Output

192.168.1.4 (tcp/80/www)

The following instance of phpMyAdmin was detected on the remote host :

Version : 3.1.1
URL : http://192.168.1.4/phpMyAdmin/

18261 (1) - Apache Banner Linux Distribution Disclosure

Synopsis

The name of the Linux distribution running on the remote host was found in the banner of the web server.

Description

Nessus was able to extract the banner of the Apache web server and determine which Linux distribution the remote host is running.

Solution

If you do not wish to display this information, edit 'httpd.conf' and set the directive 'ServerTokens Prod' and restart Apache.

Risk Factor

None

Plugin Information

Published: 2005/05/15, Modified: 2025/03/31

Plugin Output

192.168.1.4 (tcp/0)

```
The Linux distribution detected was :  
- Ubuntu 8.04 (gutsy)
```

19941 (1) - TWiki Detection

Synopsis

The remote web server hosts a Wiki system written in Perl.

Description

The remote host is running TWiki, an open source wiki system written in Perl.

See Also

<http://twiki.org>

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2005/10/06, Modified: 2023/05/24

Plugin Output

192.168.1.4 (tcp/80/www)

```
URL      : http://192.168.1.4/twiki/bin/view
Version  : 01 Feb 2003
```

20108 (1) - Web Server / Application favicon.ico Vendor Fingerprinting

Synopsis

The remote web server contains a graphic image that is prone to information disclosure.

Description

The 'favicon.ico' file found on the remote web server belongs to a popular web server. This may be used to fingerprint the web server.

Solution

Remove the 'favicon.ico' file or create a custom one for your site.

Risk Factor

None

Plugin Information

Published: 2005/10/28, Modified: 2020/06/12

Plugin Output

192.168.1.4 (tcp/8180/www)

```
MD5 fingerprint : 4644f2d45601037b8423d45e13194c93
Web server      : Apache Tomcat or Alfresco Community
```

24004 (1) - WebDAV Directory Enumeration

Synopsis

Several directories on the remote host are DAV-enabled.

Description

WebDAV is an industry standard extension to the HTTP specification.

It adds a capability for authorized users to remotely add and manage the content of a web server.

If you do not use this extension, you should disable it.

Solution

Disable DAV support if you do not use it.

Risk Factor

None

Plugin Information

Published: 2007/01/11, Modified: 2011/03/14

Plugin Output

192.168.1.4 (tcp/80/www)

```
The following directories are DAV enabled :  
- /dav/
```

39446 (1) - Apache Tomcat Detection

Synopsis

The remote web server is an Apache Tomcat server.

Description

Nessus was able to detect a remote Apache Tomcat web server.

NOTE: When paranoia levels are elevated, this plugin will also consider versions obtained from responses with non-200 HTTP status codes.

See Also

<https://tomcat.apache.org/>

Solution

n/a

Risk Factor

None

References

XREF IAVT:0001-T-0535

Plugin Information

Published: 2009/06/18, Modified: 2025/05/15

Plugin Output

192.168.1.4 (tcp/8180/www)

```
URL      : http://192.168.1.4:8180/
Version  : 5.5
backported : 0
source    : Apache Tomcat/5.5
```

40665 (1) - Protected Web Page Detection

Synopsis

Some web pages require authentication.

Description

The remote web server requires HTTP authentication for the following pages. Several authentication schemes are available :

- Basic is the simplest, but the credentials are sent in cleartext.
- NTLM provides an SSO in a Microsoft environment, but it cannot be used on both the proxy and the web server. It is also weaker than Digest.
- Digest is a cryptographically strong scheme. Credentials are never sent in cleartext, although they may still be cracked by a dictionary attack.

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2009/08/21, Modified: 2016/10/04

Plugin Output

192.168.1.4 (tcp/8180/www)

The following pages are protected by the Basic authentication scheme :

```
/host-manager/html  
/manager/html  
/manager/status
```


40773 (1) - Web Application Potentially Sensitive CGI Parameter Detection

Synopsis

An application was found that may use CGI parameters to control sensitive information.

Description

According to their names, some CGI parameters may control sensitive data (e.g., ID, privileges, commands, prices, credit card data, etc.). In the course of using an application, these variables may disclose sensitive data or be prone to tampering that could result in privilege escalation. These parameters should be examined to determine what type of data is controlled and if it poses a security risk.

** This plugin only reports information that may be useful for auditors

** or pen-testers, not a real flaw.

Solution

Ensure sensitive data is not disclosed by CGI parameters. In addition, do not use CGI parameters to control access to resources or privileges.

Risk Factor

None

Plugin Information

Published: 2009/08/25, Modified: 2021/01/19

Plugin Output

192.168.1.4 (tcp/80/www)

Potentially sensitive parameters for CGI /dvwa/login.php :

password : Possibly a clear or hashed password, vulnerable to sniffing or dictionary attack

48204 (1) - Apache HTTP Server Version

Synopsis

It is possible to obtain the version number of the remote Apache HTTP server.

Description

The remote host is running the Apache HTTP Server, an open source web server. It was possible to read the version number from the banner.

See Also

<https://httpd.apache.org/>

Solution

n/a

Risk Factor

None

References

XREF IAVT:0001-T-0030

XREF IAVT:0001-T-0530

Plugin Information

Published: 2010/07/30, Modified: 2023/08/17

Plugin Output

192.168.1.4 (tcp/80/www)

```
URL      : http://192.168.1.4/
Version  : 2.2.99
Source   : Server: Apache/2.2.8 (Ubuntu) DAV/2
backported : 1
modules  : DAV/2
os       : ConvertedUbuntu
```

48243 (1) - PHP Version Detection

Synopsis

It was possible to obtain the version number of the remote PHP installation.

Description

Nessus was able to determine the version of PHP available on the remote web server.

Solution

n/a

Risk Factor

None

References

XREF IAVT:0001-T-0936

Plugin Information

Published: 2010/08/04, Modified: 2025/05/26

Plugin Output

192.168.1.4 (tcp/80/www)

Nessus was able to identify the following PHP version information :

```
Version : 5.2.4-2ubuntu5.10
Source  : X-Powered-By: PHP/5.2.4-2ubuntu5.10
Source  : http://192.168.1.4/phpinfo.php
```

72771 (1) - Web Accessible Backups

Synopsis

The remote web server hosts web-accessible backups or archives.

Description

The remote web server is hosting web-accessible archive files that may contain backups or sensitive data.

Solution

Review each of the files and ensure they are in compliance with your security policy.

Risk Factor

None

Plugin Information

Published: 2014/03/03, Modified: 2022/04/11

Plugin Output

192.168.1.4 (tcp/8180/www)

Nessus was able to identify the following archive file on the remote web server :

ZIP Archive :
http://192.168.1.4:8180/tomcat-docs/appdev/sample/sample.war

84574 (1) - Backported Security Patch Detection (PHP)

Synopsis

Security patches have been backported.

Description

Security patches may have been 'backported' to the remote PHP install without changing its version number.

Banner-based checks have been disabled to avoid false positives.

Note that this test is informational only and does not denote any security problem.

See Also

https://access.redhat.com/security/updates/backporting/?sc_cid=3093

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2015/07/07, Modified: 2024/11/22

Plugin Output

192.168.1.4 (tcp/80/www)

Give Nessus credentials to perform local checks.